

TELECARE

Plateforme de Télémédecine

POLITIQUE DE GESTION DES HABILITATIONS

Référentiel : HDS — Hébergement de Données de Santé | RGPD
Version 1.0 — Mars 2025

Document	Politique de Gestion des Habilitations
Organisation	TeleCare SAS
Référentiels	HDS (ANS), RGPD, ISO/IEC 27001 — Contrôle A.9
Version	1.0
Date d'émission	Mars 2025
Statut	Applicable
Classification	Confidentiel — Usage interne
Propriétaire	RSSI — TeleCare
Approbateur	Direction Générale — TeleCare

1. Objet et périmètre

1.1 Objet

La présente politique définit les règles et procédures de gestion des habilitations applicables à l'ensemble du système d'information de TeleCare. Elle encadre l'attribution, la modification, la revue et la révocation des droits d'accès accordés à toute personne interagissant avec les ressources informatiques de TeleCare, et en particulier avec les données de santé à caractère personnel.

La gestion rigoureuse des habilitations est une exigence fondamentale de la certification HDS. Elle garantit que seules les personnes autorisées accèdent aux données de santé, dans le strict respect du principe du moindre privilège et de la séparation des rôles.

1.2 Périmètre d'application

Cette politique s'applique à l'ensemble des accès au système d'information TeleCare, pour toutes les catégories d'utilisateurs :

- Collaborateurs internes (CDI, CDD, stagiaires, alternants)
- Prestataires et sous-traitants techniques
- Professionnels de santé partenaires (médecins, coordonnateurs d'établissements)
- Systèmes tiers et applicatifs (comptes de service, API M2M, intégrations hospitalières)
- Administrateurs systèmes, cloud et base de données

2. Principes directeurs

La politique de gestion des habilitations de TeleCare repose sur cinq principes fondamentaux, dont le respect est non négociable dès lors que des données de santé sont en jeu :

Principe	Application chez TeleCare
Moindre privilège	Chaque utilisateur — patient, médecin, développeur, administrateur — ne dispose que des droits strictement nécessaires à l'exercice de sa fonction. Aucun droit supplémentaire n'est accordé par commodité ou anticipation.
Besoin d'en connaître	L'accès aux données de santé est conditionné au besoin métier démontré. Un médecin n'accède qu'aux dossiers de ses propres patients. Un développeur n'accède pas aux données de production sans procédure formalisée.
Séparation des rôles	Les fonctions sensibles sont séparées : un même individu ne peut pas à la fois administrer les accès et accéder aux données de santé en production. Les rôles de développement, d'exploitation et d'audit sont distincts.
Traçabilité complète	Toute attribution, modification ou révocation d'habilitation est documentée et horodatée dans le registre des habilitations. Cette traçabilité est inaltérable et disponible pour les auditeurs HDS.
Révocation sans délai	Tout changement de situation (départ, changement de poste, fin de mission) entraîne la révocation immédiate des accès correspondants, sans exception ni délai de grâce.

3. Matrice des rôles et droits d'accès

3.1 Catégories d'utilisateurs et niveaux d'accès

TeleCare distingue six catégories d'utilisateurs, chacune associée à un profil d'habilitation spécifique :

Catégorie	Accès aux données de santé	Accès administration SI	Exemples de ressources accessibles
Patient	Ses propres données uniquement	Aucun	Son dossier médical, ses ordonnances, ses résultats, son historique de consultations
Médecin / PS	Dossiers de ses patients pris en charge	Aucun	Dossiers patients assignés, outils de prescription, messagerie médicale sécurisée
Coordinateur établissement	Données agrégées non identifiantes + accès administratif limité	Aucun	Gestion des comptes médecins de son établissement, tableaux de bord anonymisés
Collaborateur métier TeleCare	Selon fonction (support, qualité...)	Aucun	Outils support, données anonymisées ou pseudonymisées selon rôle
Développeur / DevOps	Données anonymisées en dev/test uniquement — JAMAIS les données de production	Environnements hors production	Code source, CI/CD, environnements de test, monitoring technique
Administrateur systèmes	Accès technique encadré en production (procédure formalisée)	Infrastructure cloud, BDD, réseau	Consoles d'administration, journaux systèmes, outils de supervision — accès tracé et justifié

3.2 Comptes à privilèges — Règles renforcées

Les comptes d'administration (systèmes, cloud, base de données) font l'objet de mesures de sécurité renforcées, en raison de l'étendue des accès qu'ils confèrent :

Exigences obligatoires pour les comptes à privilèges

- MFA obligatoire sur tous les comptes à privilèges, sans exception ni dérogation
- Comptes nominatifs uniquement — aucun compte générique de type 'admin' ou 'root' partagé
- Restriction des accès par liste blanche d'adresses IP (VPN d'administration dédié)
- Durée de session limitée à 4 heures maximum avec verrouillage automatique
- Journalisation exhaustive de toutes les actions réalisées avec un compte à privilèges
- Principe du double regard (four-eyes) pour les opérations critiques en production (ex. modification de schéma de base de données, accès direct aux données de santé)

- Les droits d'administration sont accordés à titre temporaire pour des missions définies, et révoqués à l'issue

3.3 Comptes de service et API M2M

- Chaque compte de service ou client OAuth M2M est nominatif, rattaché à une application identifiée et documenté dans le registre des habilitations
- Les droits accordés aux comptes de service sont limités aux seules API et ressources strictement nécessaires à leur fonction
- Les secrets des comptes de service (client_secret, certificats) sont gérés via le gestionnaire de secrets centralisé et font l'objet d'une rotation annuelle minimum
- Tout compte de service inactif depuis plus de 90 jours est automatiquement désactivé

4. Cycle de vie des habilitations

4.1 Création d'un compte — Procédure d'entrée

La création de tout nouveau compte d'accès au SI TeleCare suit une procédure formalisée en quatre étapes :

Étape	Responsable	Action
1 — Demande	Responsable hiérarchique ou référent technique	Soumission d'une demande d'accès formalisée précisant : identité, rôle, ressources demandées, durée si temporaire, justification métier
2 — Validation	RSSI (ou délégué désigné)	Vérification de la conformité avec la matrice des rôles, validation ou refus motivé, enregistrement dans le registre des habilitations
3 — Provisioning	Équipe support IT / DevOps	Création du compte avec les droits validés — jamais plus que ce qui a été approuvé — envoi sécurisé des identifiants initiaux
4 — Activation	Utilisateur + RSSI	Signature de la charte informatique, changement du mot de passe initial, activation du MFA si requis, confirmation de prise en charge

Règle d'or : aucun accès sans demande approuvée

- Aucun compte ne peut être créé ni aucun accès accordé sans demande formalisée et validation préalable du RSSI.
- Les accès d'urgence (break glass) font l'objet d'une procédure spécifique, avec notification immédiate au RSSI et traçabilité renforcée.
- L'auto-provisioning d'accès par les équipes techniques est interdit pour les ressources hébergeant des données de santé.

4.2 Modification des droits

Toute modification des droits d'un utilisateur existant (élargissement, restriction, changement de rôle) suit la même procédure que la création initiale :

- Demande formalisée par le responsable hiérarchique avec justification du changement
- Validation par le RSSI avant toute mise en oeuvre
- Mise à jour du registre des habilitations avec l'horodatage et le motif
- En cas d'élargissement de droits, vérification préalable que l'utilisateur ne cumule pas des droits incompatibles (séparation des rôles)

Un utilisateur changeant de poste ou de mission voit ses anciens droits révoqués avant l'attribution des nouveaux — aucun droit n'est cumulé par défaut.

4.3 Révocation des droits — Procédure de sortie

La révocation des accès est déclenchée par les événements suivants :

Événement déclencheur	Délai de révocation	Responsable de la notification
Départ définitif (démission, licenciement, fin de contrat)	Immédiat — le jour du départ, avant restitution du matériel	RH → RSSI (notification J-5 minimum avant le départ effectif)
Fin de mission prestataire	Immédiat à la date de fin de mission contractuelle	Responsable technique → RSSI (notification J-5 minimum)
Changement de poste interne	Révocation des anciens droits avant activation des nouveaux	Responsable hiérarchique → RSSI
Arrêt maladie ou congé prolongé (> 30 jours)	Suspension des accès dans les 5 jours ouvrés	RH → RSSI
Suspicion de compromission du compte	Immédiat — sans attendre confirmation	RSSI (décision autonome)
Inactivité du compte (> 90 jours sans connexion)	Désactivation automatique	Système automatisé — revue mensuelle RSSI

Checklist de révocation — Départ d'un collaborateur

- Révocation des accès applicatifs plateforme TeleCare (compte utilisateur, rôles)
- Révocation des accès outils de développement (GitLab, CI/CD, registres Docker)
- Révocation des accès infrastructure cloud (console AWS/Azure/GCP, Kubernetes)
- Révocation des accès VPN et postes distants
- Révocation des accès aux outils collaboratifs (messagerie, documentation interne)
- Invalidation des tokens OAuth et secrets API personnels
- Restitution du matériel et vérification de l'absence de données sur supports personnels
- Archivage du compte (conservation des journaux d'activité selon durées légales)

5. Gestion des habilitations des professionnels de santé

5.1 Vérification de l'identité et des qualifications

L'accès à la plateforme TeleCare par un professionnel de santé est conditionné à une vérification préalable de son identité et de ses qualifications professionnelles :

- Vérification de l'inscription au Répertoire Partagé des Professionnels de Santé (RPPS) ou équivalent
- Validation par l'établissement de santé partenaire pour les accès initiés via un établissement
- Contrôle que le professionnel dispose bien d'une spécialité habilitée à accéder aux types de données demandés
- Signature d'un accord de confidentialité spécifique aux données de santé traitées via TeleCare

5.2 Droits d'accès par type de professionnel de santé

Profil professionnel de santé	Données accessibles via TeleCare
Médecin généraliste	Dossiers de ses patients inscrits : antécédents, ordonnances, comptes rendus de consultation, résultats d'examens qu'il a prescrit
Médecin spécialiste	Dossiers adressés par un médecin référent pour avis spécialisé — accès limité à l'épisode de soins concerné
Infirmier / Paramédical	Données nécessaires aux actes délégués par prescription médicale — pas d'accès au dossier médical complet
Pharmacien	Ordonnances en cours du patient — pas d'accès aux données de consultation ni aux résultats d'examens
Administratif établissement	Données de gestion (rendez-vous, facturation) — aucun accès aux données médicales cliniques

5.3 Gestion de la fin d'activité d'un professionnel de santé

- La cessation d'activité d'un professionnel de santé sur la plateforme entraîne la désactivation de son compte dans les 48 heures suivant la notification par l'établissement partenaire
- Les dossiers des patients suivis restent accessibles à ces patients et à leurs nouveaux médecins référents — le médecin cessant son activité n'y a plus accès
- Un médecin suspendu ou radié de l'ordre professionnel fait l'objet d'une révocation immédiate dès notification

6. Revue périodique des habilitations

6.1 Fréquence et périmètre des revues

Conformément aux exigences HDS, les habilitations font l'objet de revues périodiques selon le calendrier suivant :

Périmètre de la revue	Fréquence	Responsable
Comptes à privilèges (administrateurs systèmes, cloud, BDD)	Trimestrielle	RSSI + Responsable Technique
Comptes des professionnels de santé partenaires	Semestrielle	RSSI + Coordinateur établissements
Comptes des collaborateurs internes	Semestrielle	RSSI + Responsables d'équipes
Comptes prestataires et sous-traitants	Trimestrielle	RSSI + Responsable du contrat
Comptes de service et API M2M	Semestrielle	RSSI + Équipe DevOps
Comptes inactifs (> 60 jours sans connexion)	Mensuelle (automatisée)	Système automatisé — validation RSSI

6.2 Déroulement de la revue

Chaque revue suit le processus suivant :

- Extraction de la liste des comptes actifs et de leurs droits depuis le référentiel des habilitations
- Validation par chaque responsable d'équipe de la pertinence des droits de ses collaborateurs
- Identification des droits excessifs, des comptes inactifs et des droits devenus inadaptés au rôle actuel
- Mise à jour du référentiel et application des modifications dans les systèmes (révocations, restrictions)
- Documentation des résultats de la revue dans le registre des habilitations, avec horodatage

Les résultats des revues sont présentés au RSSI et synthétisés dans le rapport trimestriel de sécurité transmis à la Direction Générale.

6.3 Indicateurs de suivi

Indicateur	Objectif cible
Taux de comptes actifs ayant fait l'objet d'une revue dans les délais	> 100 %

Délai moyen de révocation après départ / fin de mission	< 4 heures
Nombre de comptes inactifs détectés lors des revues mensuelles	Tendance décroissante
Nombre de droits excessifs identifiés et corrigés lors des revues	Suivi et réduction trimestrielle
Taux de comptes à privilèges sans MFA actif	0 % (objectif absolu)
Délai moyen de traitement d'une demande d'accès standard	< 2 jours ouvrés

7. Registre des habilitations

TeleCare maintient un registre centralisé et à jour de l'ensemble des habilitations accordées sur son système d'information. Ce registre constitue la source de vérité pour toute décision d'accès et est requis par la certification HDS.

Le registre contient, pour chaque compte actif ou historique :

- Identité de l'utilisateur (nom, prénom, organisation)
- Catégorie et rôle (collaborateur, médecin, prestataire, compte de service...)
- Ressources et droits accordés (applications, niveaux d'accès, scopes OAuth)
- Date d'attribution et identité du validateur
- Durée de validité (permanente ou temporaire avec date d'expiration)
- Historique des modifications avec horodatage et motif
- Date de révocation et motif de révocation

Le registre est maintenu par le RSSI dans l'outil ITSM de TeleCare. Il est mis à disposition des auditeurs HDS et de la CNIL sur demande. Les entrées historiques sont conservées pendant 5 ans minimum.

8. Accès d'urgence — Procédure Break Glass

Dans des situations exceptionnelles nécessitant un accès immédiat à des ressources normalement restreintes (incident critique en production, intervention urgente sur des données de santé), une procédure d'accès d'urgence (« Break Glass ») est définie.

Conditions d'activation de la procédure Break Glass

- Incident de sécurité P1 nécessitant un accès immédiat aux données ou systèmes de production
- Panne critique affectant la disponibilité de la plateforme pour des consultations médicales en cours
- Demande médicale urgente nécessitant l'accès à un dossier patient hors procédure habituelle

La procédure Break Glass impose les obligations suivantes :

- Notification immédiate au RSSI avant ou dans les 15 minutes suivant l'accès — pas de tolérance
- L'accès est tracé intégralement dans les journaux de sécurité avec le motif d'urgence
- Un rapport post-accès est rédigé par l'utilisateur dans les 24 heures
- Le RSSI examine chaque activation de la procédure Break Glass et peut déclencher une investigation
- Tout abus de la procédure Break Glass est considéré comme une faute grave

9. Gouvernance et responsabilités

Acteur	Responsabilités liées aux habilitations
RSSI	Validation des demandes d'accès, tenue du registre des habilitations, pilotage des revues périodiques, contrôle du respect de la politique, reporting Direction
DPO	Vérification de la conformité des habilitations avec les finalités de traitement RGPD, contrôle des accès aux données de santé
Responsables d'équipes	Initiation des demandes d'accès pour leurs collaborateurs, validation lors des revues semestrielles, notification des départs et changements de poste au RSSI
RH	Notification anticipée au RSSI des arrivées, départs et changements de poste (J-5 minimum avant l'événement)
Équipe Support IT / DevOps	Mise en oeuvre technique des créations, modifications et révocations selon les instructions validées par le RSSI — jamais d'initiative autonome
Coordinateurs établissements	Notification à TeleCare des entrées et sorties de professionnels de santé de leurs établissements dans les délais contractuels

9.1 Révision de la politique

La présente politique est révisée au minimum une fois par an, ou en cas d'évolution significative de l'organisation de TeleCare, des référentiels HDS ou RGPD, ou à la suite d'un incident lié à une habilitation inappropriée.

10. Approbation et entrée en vigueur

Rédigé par	RSSI — TeleCare
Vérifié par	DPO & RH — TeleCare
Approuvé par	Direction Générale — TeleCare
Date d'approbation	Mars 2025
Date d'entrée en vigueur	Mars 2025
Prochaine révision	Mars 2026

Signature du RSSI	Signature Direction Générale
Nom : _____ Date : _____	Nom : _____ Date : _____